

CHALLENGE #25: Irish-Name-Repo 1 Write-up.

Irish-Name-Repo 1

Medium

Web Exploitation

picoCTF 2019

AUTHOR: CHRIS HENSLER

Description

Do you think you can log us in? Try to see if you can login!
Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is: **NOT_RUNNING**

Launch Instance

Hints

1 2

There doesn't seem to be many ways to interact with this. I wonder if the users are kept in a database?

25,665 users solved

picoCTF{FLAG}

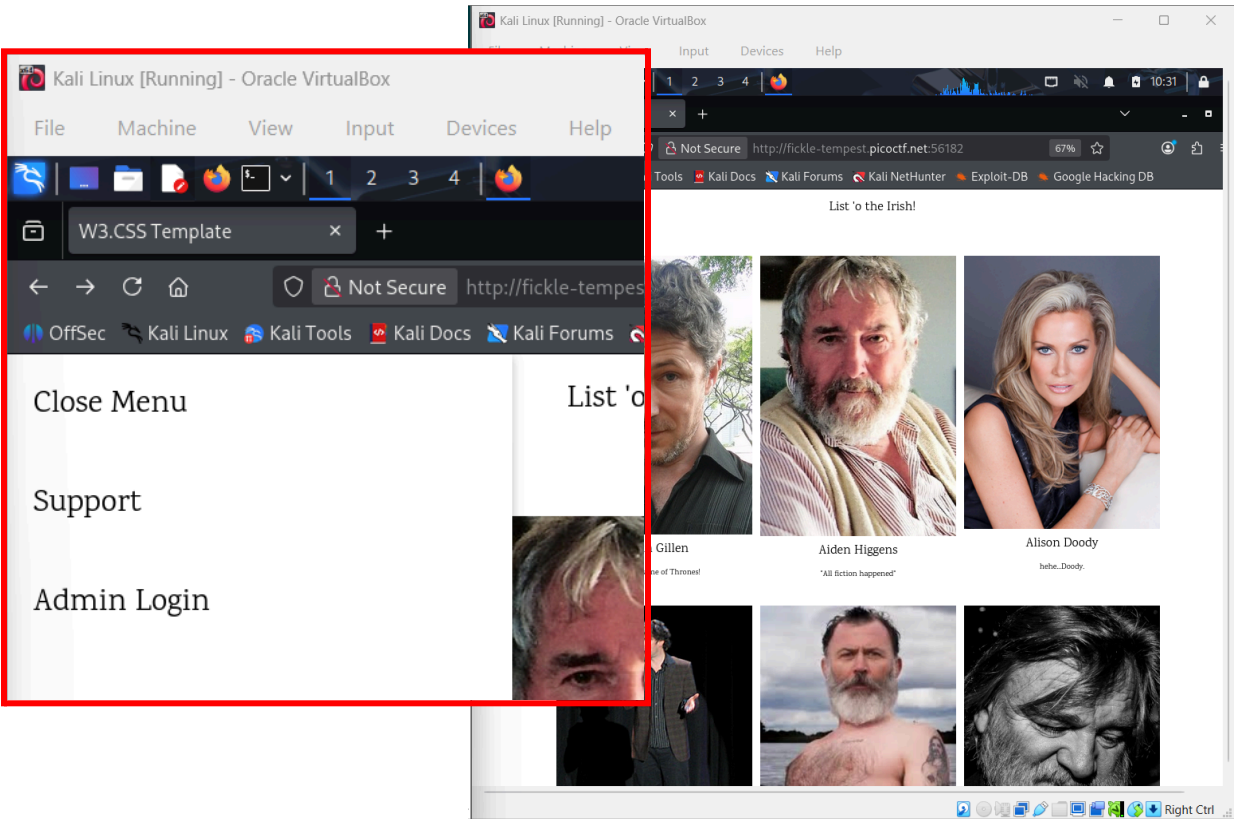
Hints

1 2

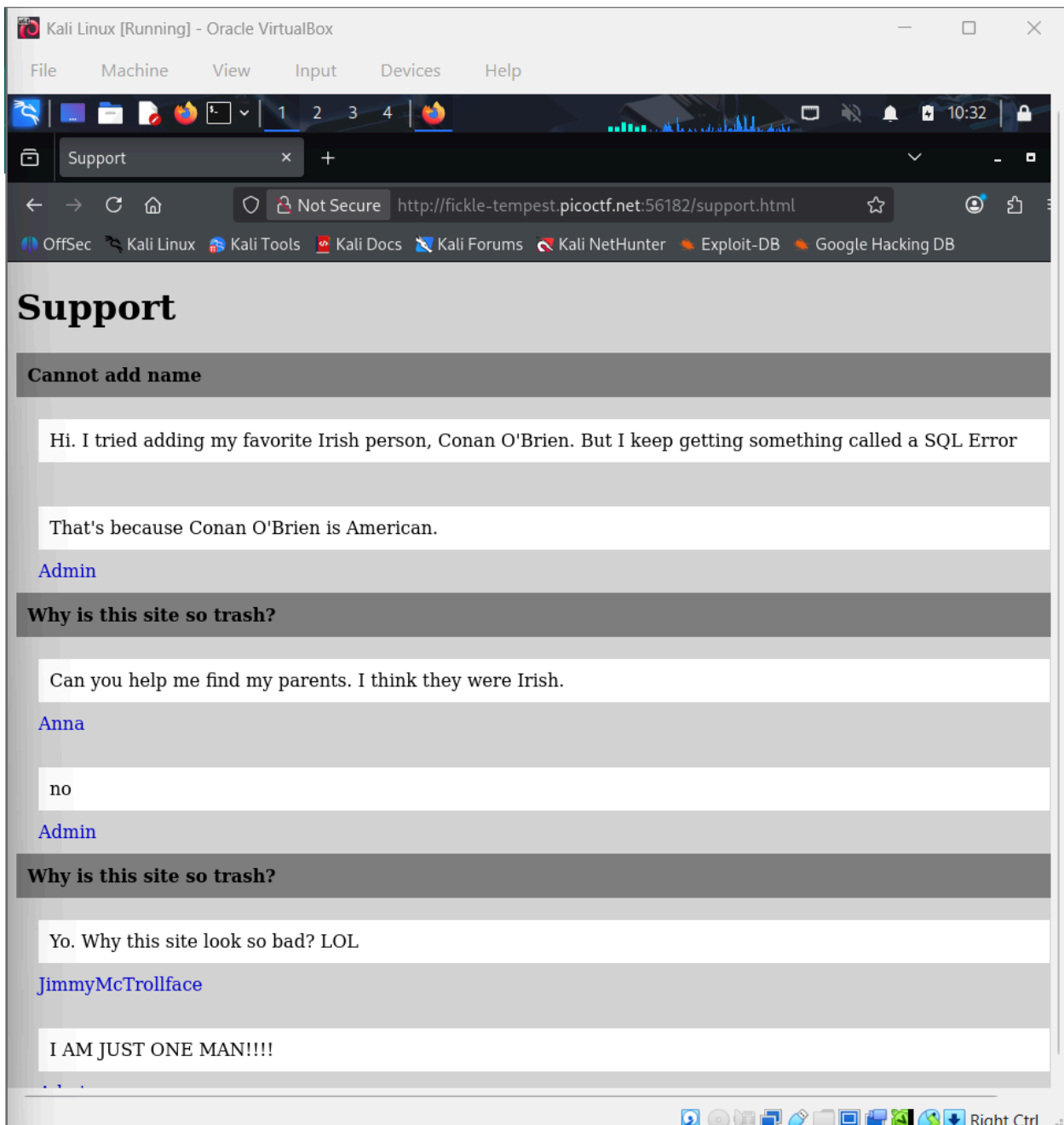
Try to think about how the website verifies your login.

Solving Process:

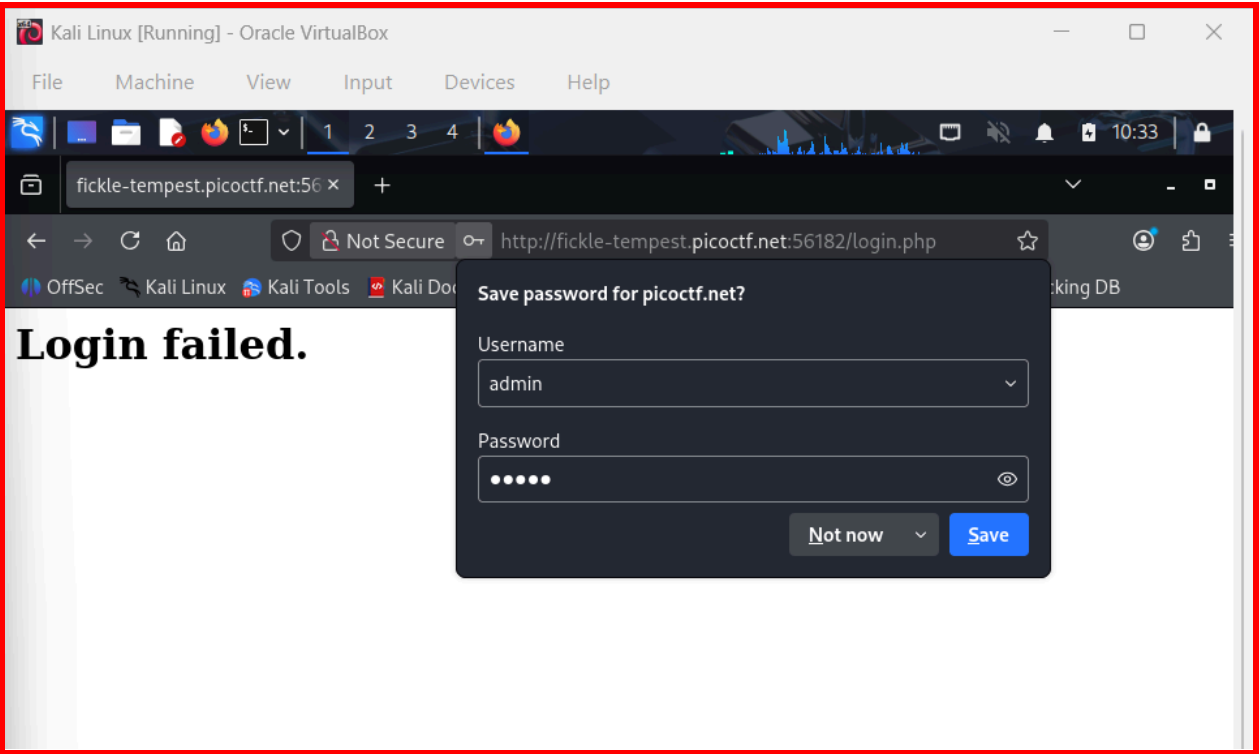
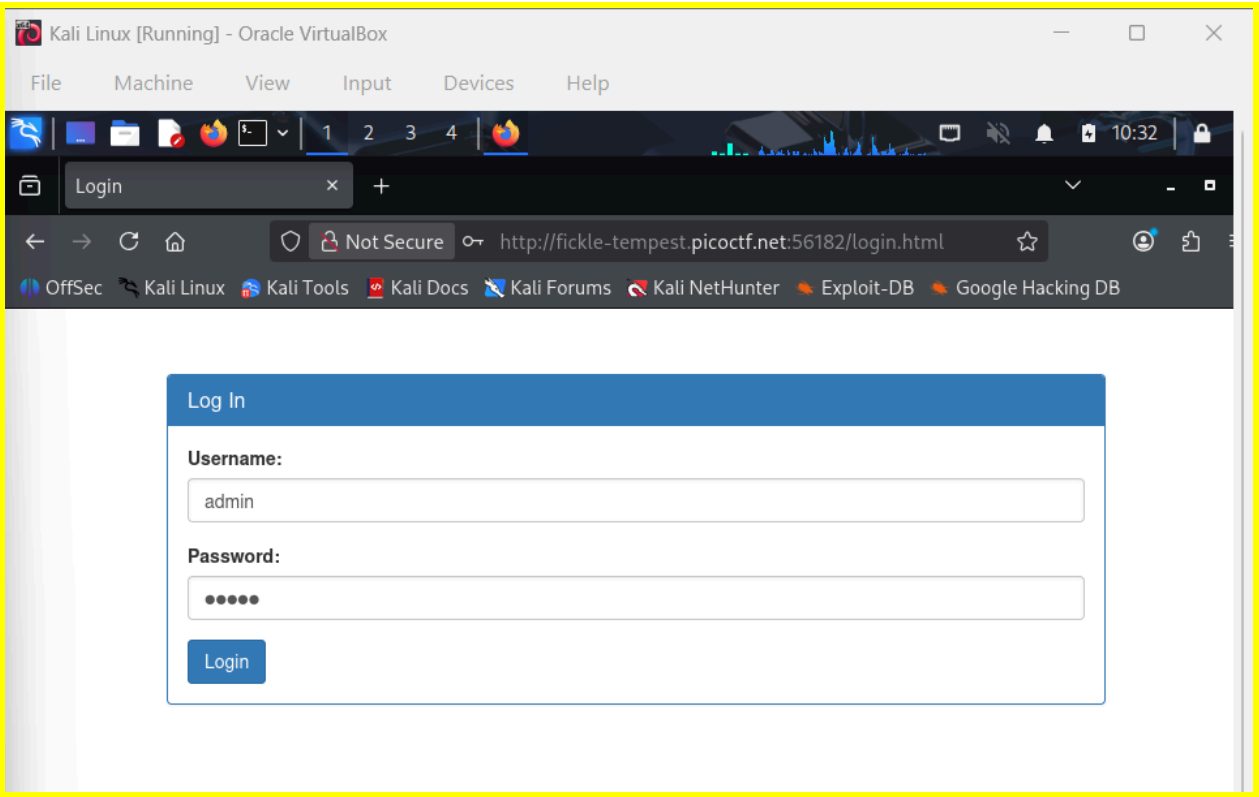
The homepage displayed a list of Irish names along with a navigation menu containing options such as **Support** and **Admin Login**.



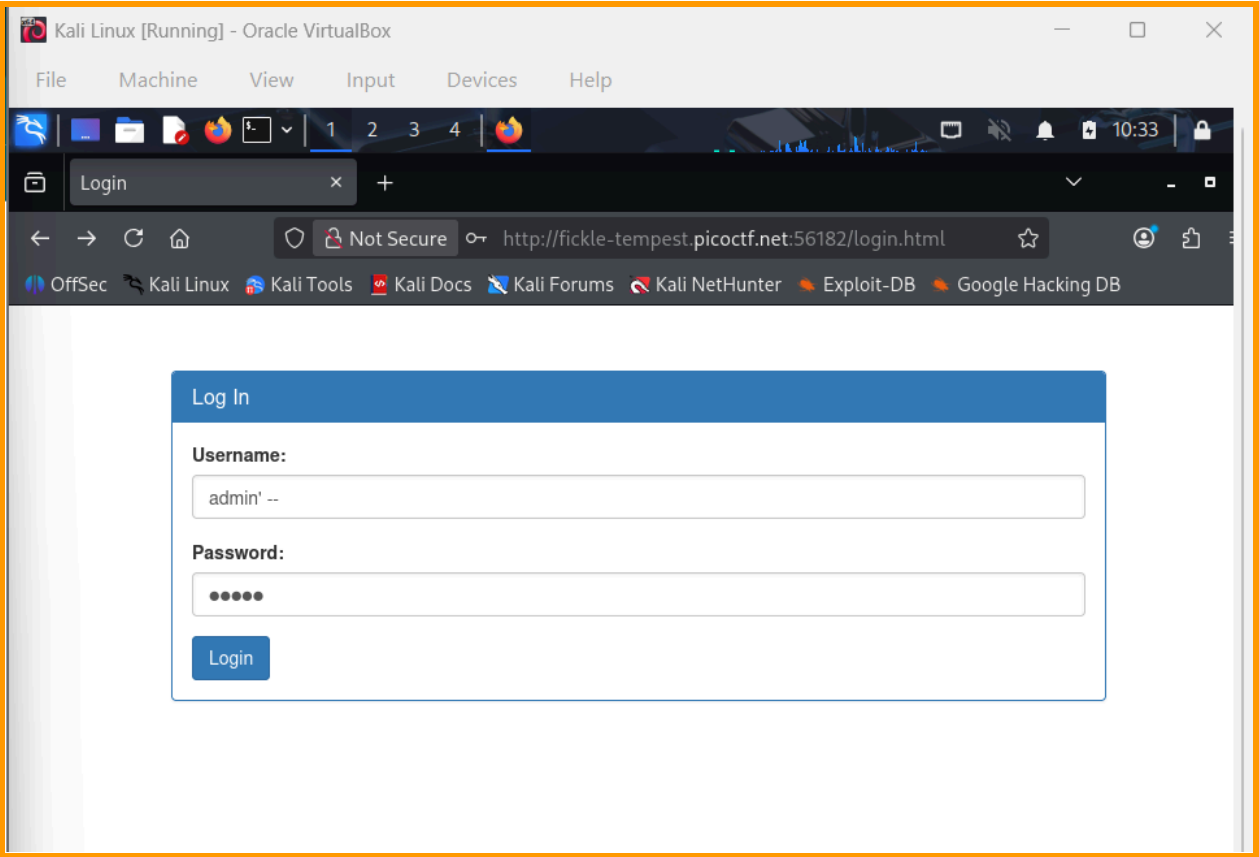
To gather more information about the website, the **Support page** was opened. On this page, several support tickets were visible. One of the tickets mentioned that a user encountered a **SQL error** when trying to add the name *Conan O'Brien* to the database. This strongly suggested that the website was connected to a SQL database, which indicated that a SQL injection vulnerability might be possible.



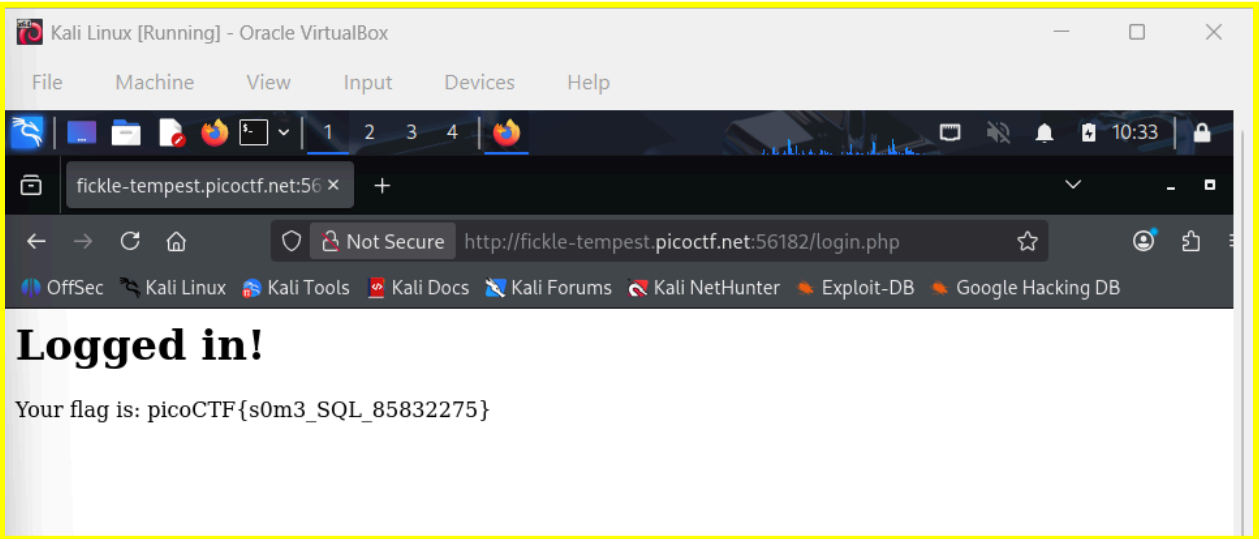
Next, the **Admin Login page** was opened. The page contained a standard login form requiring a **username** and **password**. As a basic test, the credentials **admin** and **admin** were entered, but the login attempt failed.



Since the earlier hint suggested a SQL database, a **SQL injection payload** was attempted in the username field. The input used was: `'--`. In SQL syntax, the **single quote** (`'`) closes the current query string, while the **double dash** (`--`) begins a comment in SQL. This means that anything after the comment symbol is ignored by the database query. When this payload was submitted, it effectively bypassed the authentication check by terminating the query early and commenting out the rest of the login condition.



After submitting the payload, the system granted admin access without requiring a valid password. Once logged in, the webpage displayed the flag, confirming that the SQL injection attack successfully bypassed the login mechanism.



Irish-Name-Repo 1

Medium

Web Exploitation

picoCTF 2019

AUTHOR: CHRIS HENSLER

Description

Do you think you can log us in? Try to see if you can login!
http://fickle-tempest.picoctf.net:56182.

This challenge launches an instance on demand.
Its current status is: **RUNNING**
Instance Time Remaining: **29:44**

Restart Instance

Hints ?

1

2

There doesn't seem to be many ways to interact with this. I wonder if the users are kept in a database?

25,665 users solved

94% Liked

picoCTF{s0m3_SQL_85832275}

Submit Flag

Hurray! You solved this challenge.

Reflection:

This challenge demonstrated how improperly sanitized input in SQL queries can allow attackers to bypass authentication systems. By injecting SQL syntax into the login form, it was possible to manipulate the query and gain unauthorized access. The activity highlighted the importance of using prepared statements and proper input validation to prevent SQL injection vulnerabilities.